

AI FORENSIC READINESS

A working model for reconstructing, attributing, containing, validating, and recovering from consequential actions performed or influenced by autonomous AI systems

Discussion Draft v0.1

A technical foundation for AI investigation event modeling, causal reconstruction, dependency-aware containment, verifiable revocation, and tested reversibility.

AUTHOR

Dr. Stephen Coston
Cybersecurity architect • DFIR practitioner • AI security researcher

STATUS

Open discussion draft. Designed for practitioner review, controlled testing, and iterative refinement—not as a claim of formal standardization.

RECOMMENDED LICENSE

Specification and diagrams: CC BY 4.0. Reference schemas and code: Apache License 2.0.

Executive summary

The central problem is no longer only whether an AI system can be prevented from causing harm. It is whether the organization can determine what happened when prevention fails.

Enterprises are giving AI systems access to tools, delegated identities, organizational data, persistent memory, retrieval systems, software-development workflows, cloud services, and other agents. Conventional logs may show an API call or a database change while omitting the instructions, retrieved context, memory state, policy decision, delegation path, or human approval that made the action possible.

Proposed definition

AI Forensic Readiness is the organizational and technical ability to reconstruct, attribute, contain, validate, and recover from consequential actions performed or influenced by AI systems.

What this draft contributes

- A six-question investigation model: identity, context, execution, provenance, persistence/blast radius, and recovery.
- A minimum viable evidence profile for consequential agent actions.
- An AI Incident Reconstruction Graph combining identity, authority, causality, state, and time.
- A dependency-aware containment model that treats shared credentials, memory, tools, and downstream agents as part of the incident boundary.
- A distinction between access revocation and disposition of previously acquired or derived data.
- A maturity model that ends with reversible and verifiable operations—not logging alone.

Design position

This model complements—not replaces—incident-response, AI-risk, observability, identity, and security-event standards. NIST AI RMF provides risk-management outcomes; NIST incident-response guidance structures preparation and response; OCSF provides an implementation-agnostic cybersecurity event schema; OpenTelemetry is developing GenAI semantic conventions; and OWASP documents agentic threats. This draft focuses on the investigation and recovery gap across those domains.

1. Scope and intended use

A forensic-readiness profile for systems in which AI influences or performs consequential actions.

In scope

- LLM-based and non-LLM agents that invoke tools or APIs.
- AI-assisted decisions that materially influence people, security, finance, infrastructure, code, data, or regulated workflows.
- Single-agent, multi-agent, RAG, memory-enabled, and delegated-credential architectures.
- Pre-incident evidence design, post-incident reconstruction, containment, validation, rollback, and proof of recovery.
- Cloud, SaaS, on-premises, edge, and hybrid deployment models.

Out of scope for v0.1

- A complete AI security control catalog.
- A universal telemetry schema ready for formal adoption.
- A replacement for legal discovery, safety-case analysis, model evaluation, or governance programs.
- A claim that storing complete prompts and responses is always lawful, safe, or necessary. Evidence collection must remain proportionate to risk and constrained by privacy, retention, and privilege requirements.

Audience

Primary audience	How to use this draft
Incident response / DFIR	Define evidence requirements and reconstruction procedures.
AI platform engineering	Instrument agent, model, memory, retrieval, and tool boundaries.
SOC / detection engineering	Create detections and investigation pivots across AI and conventional telemetry.
IAM / cloud security	Map delegated authority and implement effective revocation.
AI governance / risk	Convert accountability claims into testable evidence requirements.
Enterprise architecture	Evaluate whether consequential deployments are observable, containable, and reversible.

2. Why traditional DFIR assumptions break

An API event can prove that something happened without proving why the AI-mediated system caused it.

Traditional assumption	Agentic complication	Investigation consequence
A user or process initiated the action	A human instruction may be transformed through planning, retrieval, memory, and delegation	Attribution requires a chain of influence and authority.
A timeline is the primary reconstruction	Multiple agents and shared services create branching causal paths	Investigators need a graph with time overlays.
Revoking access contains future activity	Copied data, embeddings, summaries, queued work, and child agents may persist	Containment must address residual state and inherited authority.
Deleting the malicious source removes the influence	Memory or derived context may preserve it	Source removal is not state remediation.
A human approval is meaningful oversight	The approver may lack context, time, independence, or authority	Approval evidence must show what the reviewer saw and could change.
Rollback is an operational convenience	Some actions are irreversible or lack tested compensation	Reversibility should influence authorization.

Five discontinuities

Probabilistic mediation. The same high-level instruction can produce different plans, tool arguments, and actions.

Context dependence. Retrieved documents, hidden instructions, memory, policy, and system prompts may materially influence execution.

Delegated agency. The actor visible in a downstream log may be a service account used by an agent acting for another agent acting for a human.

Persistent derived state. Summaries, embeddings, caches, plans, and memories may outlive the initiating session.

Partial observability. Provider, application, identity, network, and data logs may each reveal only one portion of the trajectory.

3. Foundational principles

Readiness must be designed before the incident; post hoc logging cannot recover evidence that never existed.

P1 — Consequentiality drives evidence depth

The greater the potential impact, autonomy, irreversibility, or sensitivity, the stronger the evidence profile must be.

P2 — Authority must be traceable

Every consequential action should be traceable from downstream execution to the technical identity, agent, delegating principal, and applicable policy.

P3 — Influence must be distinguishable from execution

Prompts, retrieved content, memory, model output, planning, authorization, and execution are separate events even when a platform presents them as one interaction.

P4 — Evidence must survive the system it describes

Critical records require protected retention, integrity controls, synchronized time, and export independent of the investigated agent.

P5 — Privacy is a design constraint

Collect the minimum content necessary; support redaction, selective capture, access controls, and retention tiers.

P6 — Containment is dependency-aware

Shared tools, credentials, queues, memory stores, connectors, child agents, and downstream state belong in blast-radius analysis.

P7 — Revocation includes residual data

Stopping future API calls does not resolve data already copied, transformed, or propagated.

P8 — Reversibility is an authorization property

The ability to perform and the ability to safely compensate for an action should be assessed separately.

P9 — Human oversight must be evidenced

The record should show what the reviewer knew, when they knew it, what options existed, and whether an override was possible.

P10 — Claims must be testable

“Observable,” “contained,” “revoked,” and “recovered” require defined evidence and validation procedures.

4. The six-question investigation model

Every investigation should be able to answer six questions without relying on the agent's own retrospective explanation.

Dimension	Core question	Minimum proof
Identity	Who or what acted, and for whom?	Human principal, agent identity/version, runtime identity, delegated identity, tenant and session.
Context	What information and instructions influenced the action?	Instruction references, prompt/policy versions, retrieval set, memory reads, relevant state.
Execution	What was requested, authorized, attempted, and completed?	Plan/step, tool call, normalized arguments, authorization decision, result, retries.
Provenance	Where did claims, instructions, and decision inputs originate?	Source identifiers, hashes, retrieval path, transformations, trust labels.
Persistence / blast radius	What durable state changed or propagated?	Memory writes, data mutations, artifacts, queues, embeddings, child tasks, downstream consumers.
Recovery	Can access and influence be revoked, actions reversed, and containment proven?	Revocation records, compensating actions, validation queries, residual-risk disposition.

Investigation completion criteria

- The initiating principal and delegated authority chain are identified or explicitly recorded as unresolved.
- The causal path from influential input to consequential state change is supported by independent evidence.
- All known persistent state changes and downstream consumers are enumerated.
- Containment actions are mapped to each dependency, not only to the originating agent.
- Recovery validation demonstrates what was reversed, revoked, retained, or accepted as residual risk.
- Evidence gaps and confidence are reported; missing telemetry is not silently converted into certainty.

5. AI investigation event model

A vendor-neutral logical model for recording consequential trajectories across heterogeneous systems.

Core event envelope

Field group	Representative fields	Purpose
Event	event_id, event_type, timestamp, observed_at, sequence, severity	Orders and classifies evidence.
Correlation	trace_id, session_id, parent_event_id, task_id, workflow_id	Links events across services and agents.
Principal	human_id, agent_id, runtime_id, delegated_identity, tenant_id	Establishes attribution and authority.
AI component	agent_version, model_id/version, provider, system_prompt_version, policy_version	Pins behavior to deployed configuration.
Influence	instruction_ref, retrieved_context_refs, memory_read_refs, source_provenance	Records material inputs without requiring indiscriminate full-content capture.
Decision	plan_step, policy_decision, risk_score, approval_required, approval_ref	Separates reasoning artifacts and policy gates from execution.
Action	tool_id/version, operation, arguments_digest, target, result, error, retry	Describes attempted and completed operations.
State	before_ref, after_ref, mutation_type, persistence_scope, downstream_refs	Supports blast-radius and recovery analysis.
Integrity	collector, schema_version, hash, signature, retention_class, access_label	Supports evidentiary reliability and handling.

Content-capture rule

Prefer references, digests, classifications, and selectively retained snapshots over universal raw prompt capture. Full content may be necessary for high-impact use cases, but its collection creates privacy, privilege, intellectual-property, insider-risk, and breach-concentration concerns.

Event types proposed for v0.1

- ai.session.started / ended
- ai.instruction.received / transformed
- ai.context.retrieved / filtered
- ai.memory.read / written / deleted
- ai.plan.created / revised
- ai.policy.evaluated
- ai.approval.requested / granted / denied / expired
- ai.tool.requested / authorized / executed / failed
- ai.delegation.created / accepted / revoked
- ai.state.changed / compensated / validated
- ai.evidence.exported / sealed

6. Minimum viable evidence profile

The smallest defensible evidence set for a consequential agent action.

Evidence domain	Required for consequential actions	Enhanced profile
Time and correlation	UTC timestamp, monotonic sequence where available, trace/session/task identifiers	Clock-quality metadata and cross-domain correlation confidence.
Identity and authority	Human principal, agent/runtime identity, delegated credential, authorization result	Full delegation chain, token scope snapshot, entitlement version.
Configuration	Agent, model, tool, policy, and prompt-template versions	Immutable deployment manifest and evaluation status.
Influence	Material instruction/context/memory references and provenance	Protected snapshots, transformation lineage, trust scores.
Execution	Requested operation, normalized arguments or digest, target, outcome	Network/data-plane corroboration and before/after state.
Oversight	Approval decision, reviewer, time, displayed summary	Exact evidence shown, alternatives, override ability, independence.
Persistence	Memory/data/artifact mutations and downstream references	Derived-data registry, propagation receipts, deletion attestations.
Integrity	Collector identity, schema version, retention, access control	Signed batches, transparency log, independent evidence vault.

Evidence quality properties

- Complete enough to answer the six investigation questions for the relevant risk tier.
- Correlated across agent, model, tool, IAM, application, cloud, network, and data layers.
- Tamper-evident and protected from modification by the investigated workload.
- Exportable in a documented, machine-readable format without proprietary UI dependence.
- Interpretable: versions, identifiers, time semantics, and field meanings are documented.
- Proportionate: collection and retention are justified against consequence, privacy, and legal constraints.

7. AI Incident Reconstruction Graph

A relationship model that overlays time rather than forcing branching behavior into a flat chronology.

Graph definition

The AI Incident Reconstruction Graph (AIRG) represents entities and evidence-backed relationships needed to explain identity, authority, influence, causality, execution, persistence, and recovery over time.

Node classes

Node class	Examples
Principal	human, organization, service principal, workload identity
AI system	agent, model endpoint, orchestrator, policy engine
Information	instruction, retrieved document, memory item, system prompt, model output
Capability	tool, API, connector, skill, function
State	database record, cloud resource, code commit, ticket, email, embedding
Evidence	log record, trace span, approval record, hash, snapshot
Recovery action	revoke, isolate, delete, compensate, restore, validate

Edge classes

instructed • retrieved • influenced • planned • delegated-to • assumed-identity • requested • authorized • approved • executed • modified • persisted-as • propagated-to • contained-by • reversed-by • validated-by

Required edge attributes

- timestamp or interval
- source evidence reference
- confidence: confirmed / strongly supported / inferred / disputed
- authority basis
- sequence or parent relationship
- collector and integrity metadata

Analyst rule

The graph may include hypotheses, but every inferred edge must be visibly distinguished from observed evidence. A model-generated explanation is a lead, not independent corroboration.

8. Dependency-aware containment

The incident boundary follows capability and state dependencies—not the label of the originating agent.

Containment inventory

Dependency	Questions investigators must answer
Delegated identity	Which tokens, scopes, sessions, or workload identities remain usable?
Tools and connectors	Which other agents or workflows share the same capability?
Memory / vector stores	What was written, indexed, summarized, or made retrievable?
Queues and scheduled work	What tasks can execute after the visible session ends?
Child agents / workflows	What authority or context was inherited?
Downstream systems	Which records, permissions, messages, code, or infrastructure changed?
Derived data	Where do copies, summaries, embeddings, exports, or caches remain?
Human processes	What decisions were already made based on compromised output?

Containment sequence

1. Freeze or checkpoint volatile evidence before destructive remediation when safe.
2. Suspend high-risk execution paths and approval queues.
3. Revoke or narrow delegated authority at each identity boundary.
4. Isolate affected memory, retrieval corpora, tools, and child workflows.
5. Enumerate durable changes and downstream consumers.
6. Apply compensating actions or restore known-good state.
7. Validate each containment claim through independent queries and controls.
8. Record residual state that cannot be removed and assign an accountable risk owner.

9. Verifiable revocation and reversibility

“Disconnected” describes future access. It does not prove disposition of information or effects already acquired.

Two-part revocation

Property	Question	Evidence
Prospective revocation	Can the agent make another authorized call?	Token invalidation, connector disablement, denied validation call, session termination.
Retrospective disposition	What previously acquired or derived information remains?	Data lineage, memory/vector search, cache inventory, deletion/retention record, downstream notification.

Reversibility classes

Class	Meaning	Authorization implication
R0 — Naturally reversible	A reliable native undo exists and is tested.	May support bounded autonomous execution.
R1 — Compensable	No true undo, but a tested compensating action restores acceptable state.	Require monitoring and evidence of compensation.
R2 — Recoverable with cost	Restoration is possible but slow, lossy, or operationally disruptive.	Stronger approval and narrower scope.
R3 — Irreversible	Disclosure, external communication, destructive act, or decision cannot be fully undone.	Human authorization or prohibition for high-impact use.

Proposed authorization principle

“Can execute” and “can safely reverse or compensate” should be distinct policy dimensions. An agent’s authority should decrease as impact and irreversibility increase.

10. Human oversight evidence

A human in the loop is not meaningful merely because an approval button exists.

Meaningful oversight test

Dimension	Evidence question
Identity	Who reviewed the action, and were they authorized?
Information	What context, uncertainty, evidence, and alternatives were shown?
Time	Was there sufficient time to evaluate the consequence?
Authority	Could the reviewer modify, reject, delay, escalate, or reverse the action?
Independence	Was the review free from the same compromised source or automation path?
Competence	Did the reviewer have the subject-matter capability required?
Outcome	What decision was made, why, and what changed afterward?

A reviewer presented only with the agent's conclusion may be unable to detect the faulty assumptions or poisoned context that produced it. High-impact workflows should preserve the evidence actually displayed to the reviewer—not merely a boolean approved=true value.

Anti-rubber-stamp controls

- Risk-based sampling of approvals and reversals.
- Separation of duties for the highest-impact actions.
- Display of source provenance and uncertainty, not only recommendations.
- Minimum review time or forced justification where appropriate.
- Escalation paths that do not depend on the same agent under review.
- Measurement of override frequency, correction quality, and reviewer workload.

11. AI forensic-readiness maturity model

Maturity is demonstrated through tested investigative and recovery capability, not policy statements.

Level	Operational outcome	Representative evidence
0 — Invisible	Consequential AI activity cannot be reliably reconstructed.	Unknown agent inventory; logs fragmented or absent.
1 — Observable	Basic interactions and downstream API activity are available.	Prompt/response or tool logs exist but identity and state linkage are weak.
2 — Attributable	Actions map to humans, agents, models, tools, and delegated identities.	Versioned identities and authority records are correlated.
3 — Reconstructable	Investigators can reproduce the material context, delegation, execution, and state path.	AIRG can be built with documented evidence gaps and confidence.
4 — Containable	Dependencies, inherited authority, persistent state, and downstream impact can be scoped and isolated.	Containment exercises validate multi-system blast-radius control.
5 — Reversible & verifiable	Consequential actions have tested recovery paths; revocation and containment can be independently proven.	Compensating actions, residual-data disposition, and validation evidence are routine.

Scoring rule

Score each deployed use case separately across evidence, attribution, reconstruction, containment, revocation, reversibility, and oversight. The overall readiness level should not exceed the lowest capability required for the use case's plausible high-impact incident. A polished enterprise average must not conceal a critical agent operating at Level 0 or 1.

12. Reference architecture

A logical architecture; products may combine or distribute these functions.

Layer	Required capabilities
Sources	Human and workload identity; agent runtime; model gateway; system prompts/policy; RAG; memory; tools/MCP; SaaS/cloud/data; approvals.
Collection	Structured events, distributed traces, protected content references, snapshots, version manifests, clock metadata.
Normalization	Vendor-neutral event envelope; schema mapping; identity resolution; redaction and retention classification.
Evidence protection	Write-separated store; access controls; integrity digests/signatures; immutable retention where warranted; export.
Reconstruction	Timeline plus AIRG; authority chain; provenance; state diffs; confidence and evidence-gap tracking.
Response	Dependency discovery; token/session revocation; workflow isolation; memory quarantine; compensating actions.
Validation	Independent queries, denied-call tests, state reconciliation, residual-data disposition, closure evidence.

Interoperability direction

Use OCSF-compatible extension patterns for normalized security events where practical, OpenTelemetry trace context for cross-service correlation where implemented, and existing IAM/cloud/SaaS audit records as corroborating evidence. Avoid defining new fields when a stable, semantically equivalent field already exists. The proposed event types should be tested as an extension before any claim of standard contribution.

Evidence trust boundaries

- The agent should not be able to erase or rewrite authoritative evidence of its own consequential actions.
- Provider-generated telemetry should be corroborated with customer-controlled evidence for high-impact events where feasible.
- The evidence vault should use separate administrative authority and retention policy from the agent platform.
- Collection failures, sampling, redaction, and dropped events must themselves be observable.

13. Reference investigation cases

Ten deep cases should become the laboratory for validating and refining this model.

Case	Scenario	Primary validation question
01 Prompt injection → tool abuse	Malicious retrieved content causes confidential-data access and external transmission.	Can influence, policy, delegated identity, tool call, and egress be reconstructed?
02 Persistent memory poisoning	A malicious fact is stored and retrieved days later by another workflow.	Can investigators identify every read, write, consumer, and derivative?
03 Delegation containment failure	Agent A delegates to B through identity C; isolating A does not stop B.	Does dependency discovery find inherited authority?
04 Unverifiable revocation	Email access is revoked, but summaries and embeddings remain.	Can prospective and retrospective revocation be separately proven?
05 Tool description manipulation	A compromised capability description changes tool selection or arguments.	Are tool/version provenance and authorization visible?
06 Approval compromise	A reviewer approves an action based on an incomplete or manipulated summary.	What did the reviewer see and could they override?
07 Cross-tenant or cross-workflow memory exposure	Context from one boundary influences another.	Can source tenant, retrieval path, and affected decisions be identified?
08 Model or policy version drift	Behavior changes after an update without corresponding evidence baselines.	Can incidents be pinned to exact configuration and evaluation state?
09 Irreversible external action	An agent sends a message, executes a trade, or publishes data.	Was irreversibility part of authorization and what compensation exists?
10 Evidence-gap exercise	Key provider telemetry is absent or sampled.	Can investigators state uncertainty and use independent sources?

14. Assessment and exercise method

A repeatable way to turn the model into measurable enterprise evidence.

Assessment workflow

9. Select one consequential AI use case and define its plausible high-impact actions.
10. Draw the actual authority and dependency graph, including people, agents, credentials, tools, stores, queues, and downstream systems.
11. Map each six-question requirement to authoritative evidence sources and retention.
12. Execute a controlled reference case and collect the evidence without privileged developer knowledge.
13. Construct the AIRG and document confirmed, inferred, disputed, and missing edges.
14. Perform dependency-aware containment and each applicable rollback or compensating action.
15. Independently validate revocation, state recovery, and residual-data disposition.
16. Score maturity by dimension; create engineering work tied to demonstrated gaps.

Core metrics

Metric	Definition
Reconstruction coverage	Percentage of material nodes/edges supported by authoritative evidence.
Attribution completeness	Percentage of consequential actions mapped to principal and authority chain.
Evidence latency	Time from event to investigator-accessible protected record.
Containment completeness	Percentage of identified dependencies with executed and validated controls.
Recovery success	Percentage of state changes reversed or acceptably compensated.
Residual-state disposition	Percentage of derived/persistent artifacts deleted, retained with justification, or unresolved.
Time to defensible narrative	Time until investigators can state what happened with confidence and gaps.

15. Publication, hosting, and governance plan

Publish the specification as an open practitioner project; keep implementation artifacts and formal papers in complementary channels.

Recommended publication stack

Channel	What to publish	Why it belongs there
GitHub — primary home	Markdown specification, schemas, diagrams, reference cases, issue templates, changelog, licenses.	Version control, transparent review, citations to exact releases, community contribution.
Zenodo — archival releases	PDF plus release bundle for v0.1, v0.2, and major versions.	Creates a DOI and durable, citable research record; can archive GitHub releases.
Personal site — canonical landing page	Plain-language overview, current release, diagrams, talks, cases, contact/contribution links.	Own the category narrative and create a stable discovery destination.
LinkedIn / Substack — distribution	Case-based explanations and lessons tied back to the canonical release.	Reach practitioners without fragmenting the authoritative source.
SSRN or arXiv — later paper	Flagship paper after practitioner review and reference-case results.	Academic-style discovery and citation; stronger after empirical validation.
Conferences / communities	Talks, workshops, FIRST/H-ISAC/OWASP contributions.	Pressure-test the model and recruit technical reviewers.

Repository recommendation

Suggested name

ai-forensic-readiness — a separate, neutral repository under the Scoston GitHub account or a dedicated organization. AI-DFIR remains the implementation laboratory and links back to the specification.

- /spec — normative Markdown and glossary
- /schemas — JSON Schema and example OCSF/OpenTelemetry mappings
- /cases — controlled investigations, evidence bundles, and analyst guides
- /architecture — portable Mermaid/SVG diagrams
- /assessments — maturity worksheets and exercise templates
- /research — survey instruments and anonymized findings
- /rfcs — proposed changes and design decisions

Release and contribution model

- Tag v0.1 as a discussion draft, not a standard.
- Open a 45-day public comment period using structured GitHub issues.
- Require every proposed field to include an investigation question, use case, privacy impact, and existing-standard mapping.
- Maintain normative (“must/should/may”) and informative material separately in later versions.
- Name contributors and reviewers transparently; record conflicts and unresolved objections.
- Use CC BY 4.0 for prose/diagrams and Apache-2.0 for schemas/code.

16. Ninety-day build plan

The objective is not more features. It is a defensible v0.1, three reproducible cases, and visible practitioner review.

Window	Deliverables	Exit criterion
Days 1–14	Publish discussion draft; create repository structure, glossary, contribution guide, and issue templates.	A reviewer can understand the claim, scope, and proposed evidence model without a meeting.
Days 15–35	Implement Case 01: prompt injection → tool abuse; create event bundle and AIRG.	A second investigator can reconstruct the trajectory from the evidence package.
Days 36–55	Implement Case 02: persistent memory poisoning.	The case demonstrates delayed influence and identifies every known persistent-state dependency.
Days 56–75	Implement Case 03: delegated credential containment failure.	Containment validation shows why isolating the parent agent is insufficient.
Days 76–90	Integrate findings into v0.2; publish a practitioner briefing and invite named technical review.	Changes are tied to case evidence and public comments—not preference alone.

Decisions to make now

- Use “AI Forensic Readiness” as the umbrella category and “Agentic Incident Response” as an operational subdomain.
- Keep the specification repository independent from AI-DFIR so the intellectual model is not mistaken for one product.
- Publish under your name initially; form a steering group only after sustained external contribution.
- Avoid trademark-heavy positioning at v0.1. Build citations, tests, and practitioner adoption first.
- Measure success by external use: reviews, reproduced cases, schema mappings, talks accepted, and organizations running the assessment.

First public message

When an AI agent takes a consequential action, most organizations can see fragments of what happened. Few can reconstruct the full chain of instruction, context, delegated authority, tool execution, persistent state, and recovery. AI Forensic Readiness v0.1 is a working model for closing that gap.

Appendix A — Readiness checklist

A compact pre-deployment gate for consequential AI use cases.

- ☐ Named human and technical owner
- ☐ Documented consequential actions and impact tiers
- ☐ Unique agent/runtime identity and versioning
- ☐ Traceable human-to-agent-to-tool authority chain
- ☐ Versioned model, prompt, policy, tool, and retrieval configuration
- ☐ Cross-service trace/session/task correlation
- ☐ Material context and provenance references
- ☐ Memory reads/writes and persistent-state visibility
- ☐ Requested vs. authorized vs. executed action separation
- ☐ Human approval evidence sufficient to test meaningful oversight
- ☐ Protected evidence export outside agent control
- ☐ Dependency inventory for credentials, tools, stores, queues, and child agents
- ☐ Tested prospective credential/session revocation
- ☐ Documented retrospective data disposition
- ☐ Rollback or compensating action class for each consequential operation
- ☐ Independent containment and recovery validation
- ☐ Privacy, retention, privilege, and access-control review
- ☐ Tabletop or controlled exercise completed
- ☐ Evidence gaps and residual risk accepted by an accountable owner

Appendix B — Terminology and references

Terms are intentionally operational; later versions should align definitions with stable standards where equivalent.

Agent — An AI-enabled software entity that selects or sequences actions toward an objective with some degree of autonomy.

Consequential action — An action or recommendation capable of materially affecting people, data, money, infrastructure, code, security, compliance, or external commitments.

Delegated identity — A credential or workload identity used by an agent under authority originating from another principal.

Derived state — A summary, embedding, cache, plan, artifact, or other transformed information created from acquired inputs.

Evidence gap — A material fact or relationship that cannot be established at the required confidence due to absent, unreliable, inaccessible, or conflicting evidence.

Verifiable revocation — Evidence that future access is terminated and previously acquired or derived data has a documented disposition.

Compensating action — An operation that mitigates or restores acceptable state when a true reversal is unavailable.

AIRG — AI Incident Reconstruction Graph: the evidence-backed graph of identity, authority, influence, causality, execution, persistence, and recovery.

Informative references

[1] NIST, Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1, 2023. <https://doi.org/10.6028/NIST.AI.100-1>

[2] NIST, Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, NIST AI 600-1, 2024. <https://doi.org/10.6028/NIST.AI.600-1>

[3] NIST, Computer Security Incident Handling Guide, SP 800-61 Rev. 2 (and successor guidance as applicable). <https://csrc.nist.gov/publications/detail/sp/800-61/rev-2/final>

[4] Open Cybersecurity Schema Framework (OCSF), schema and documentation. <https://ocsf.io/>

[5] OpenTelemetry, Semantic Conventions for Generative AI Systems. <https://opentelemetry.io/docs/specs/semconv/gen-ai/>

[6] OWASP GenAI Security Project, Agentic AI — Threats and Mitigations, 2025. <https://genai.owasp.org/resource/agentic-ai-threats-and-mitigations/>

[7] OWASP GenAI Security Project, Top 10 for Agentic Applications 2026. <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/>

Author note: The six-question model, AIRG framing, verifiable-revocation distinction, reversibility classes, and maturity model in this draft are proposed contributions for public testing and review. Alignment references do not imply endorsement by the cited organizations.